

Manual 22 — Implementación controlada de seguridad en la nube

Localización controlada es-419 — desarrollo

****Orden de la serie:**** 22

****Fuente inglesa vinculante:**** blob `a056997ce359c3a37acc5b931e5f808cc09921be`

****Estado de referencia principal:**** Cloud Security Alliance Cloud Controls Matrix (CCM) v4.1

****Límite:**** Guía de implementación original. La orientación nativa de proveedores es evidencia de implementación y no sustituye leyes aplicables, estándares independientes ni la intención de controles de CSA. Los crosswalks son mapeos, no equivalencias. Esta traducción del proyecto es no oficial y no implica registro, atestación o certificación CSA STAR.

1. Gobierno de nube y modelo operativo

Definir responsabilidad ejecutiva, propietarios de seguridad, responsabilidades de plataforma y aplicaciones, aceptación de riesgo, autoridad de arquitectura, incorporación de servicios y jerarquía de políticas. Evidencia: carta de gobierno, RACI, estándares, excepciones y decisiones de gestión.

2. Alcance, tenencia, cuentas, suscripciones, proyectos y landing zones

Mantener alcance autoritativo de organizaciones, tenants, cuentas, suscripciones, proyectos, regiones, ambientes y propietarios. Usar aprovisionamiento y etiquetado gobernados. Evidencia: inventarios, jerarquías, definiciones de landing zone y conciliación con APIs del proveedor.

3. Responsabilidad compartida y asignación contractual

Documentar responsabilidades según modelo de servicio, despliegue, capacidades, contratos y servicios administrados. Evidencia: matrices de responsabilidad, cláusulas, declaraciones de control, obligaciones del cliente, brechas y disparadores de reevaluación.

4. Evaluación de riesgo y registros de decisión de arquitectura

Evaluar riesgo considerando sensibilidad, criticidad, rutas de identidad, exposición, dependencia del proveedor, concentración regional, cadena de suministro y resiliencia. Evidencia: evaluaciones, modelos de amenazas, ADR, supuestos, riesgo residual y aprobaciones.

5. Federación de identidad, autenticación y acceso privilegiado

Centralizar identidad cuando sea viable, exigir autenticación fuerte, limitar privilegios y proteger identidades de emergencia. Evidencia: configuración de federación, MFA, roles privilegiados, elevaciones, revisiones y pruebas de break-glass.

6. Identidad de cargas y principales de servicio

Gobernar cuentas de servicio, identidades administradas, federación de cargas, principales, certificados y credenciales automatizadas. Preferir credenciales de corta duración. Evidencia: inventario, propiedad, permisos, antigüedad, políticas de confianza y rotación.

7. Arquitectura de red, segmentación, ingreso y egreso

Definir patrones aprobados, segmentación, enrutamiento, ingreso desde Internet, egreso, conectividad privada, DNS y acceso administrativo. Evidencia: diagramas, matrices de flujo, reglas, tablas de rutas, controles de egreso, pruebas y excepciones.

8. Patrones Zero Trust y confianza servicio a servicio

Autenticar y autorizar conexiones con identidad verificada, contexto y mínimo privilegio, no solo ubicación de red. Evidencia: arquitectura de confianza, identidades de servicio, políticas, certificados, pruebas y denegaciones observadas.

9. Clasificación, residencia, soberanía y ciclo de vida de datos

Clasificar datos y mapear dónde se crean, almacenan, procesan, replican, respaldan, transfieren y eliminan. Evidencia: inventarios, clasificación, regiones, rutas de transferencia, retención y decisiones aprobadas de ubicación.

10. Cifrado, gestión de claves, HSM y secretos

Definir cifrado en reposo y tránsito, propiedad y rotación de claves, KMS/HSM, separación de funciones y gestión de secretos. Evidencia: inventarios, políticas, configuraciones, almacenes, rotaciones, registros y excepciones.

11. Registros, telemetría, auditoría e integridad temporal

Habilitar eventos administrativos, de identidad, red, datos, cargas y plataforma; proteger registros y mantener retención y tiempo coherente. Evidencia: estándar, fuentes, salud de ingestión, retención, destinos protegidos y controles de acceso.

12. Ingeniería de detección, monitoreo de amenazas y servicios nativos

Desarrollar detecciones para abuso de credenciales, escalamiento, APIs sospechosas, recursos expuestos, exfiltración y cambios de políticas. Evidencia: reglas, cobertura, pruebas, investigaciones, ajuste y métricas.

13. Líneas base de configuración y policy as code

Definir configuraciones seguras y evaluarlas o aplicarlas mediante motores de políticas cuando corresponda. Evidencia: líneas base, repositorios, asignaciones, resultados, bloqueos, excepciones y remediación de deriva.

14. Gobierno de infraestructura como código y control de deriva

Gestionar infraestructura mediante repositorios controlados, revisión, pruebas, aprobaciones y pipelines protegidos. Evidencia: repositorios IaC, revisiones, planes, resultados, reportes de deriva y conciliaciones.

15. Vulnerabilidades, parches, imágenes y dependencias

Inventariar y priorizar vulnerabilidades según exposición, explotabilidad, criticidad y responsabilidad del proveedor. Evidencia: cobertura, hallazgos, estado de parches, alertas, tickets, excepciones, retests y avisos.

16. Seguridad de contenedores, Kubernetes y orquestación

Proteger clusters, planos de control, nodos, registros, admisión, RBAC, namespaces, políticas de red, secretos e imágenes. Evidencia: inventarios, líneas base, políticas, procedencia de imágenes, revisiones y alertas.

17. Seguridad serverless, PaaS, servicios administrados y APIs

Aplicar controles específicos a funciones, bases administradas, colas, analítica, IA, APIs y otros PaaS. Evidencia: inventarios, políticas API, configuraciones, registros, datos y decisiones de riesgo.

18. Seguridad SaaS y aseguramiento de configuración del tenant

Gobernar administradores, federación, MFA, compartición, colaboración externa, retención, integraciones y registros. Evidencia: inventario SaaS, revisiones de roles, evaluaciones, aplicaciones conectadas y remediación.

19. DevSecOps, CI/CD, firma e integridad de compilación

Proteger repositorios, runners, sistemas de build, identidades de despliegue, artefactos y registros. Evidencia: pipelines, revisiones de acceso, escaneos, artefactos firmados, atestaciones de procedencia y releases.

20. Respaldo, recuperación, inmutabilidad y resiliencia ante ransomware

Definir cobertura de respaldo protegida, aislamiento, inmutabilidad cuando aplique, retención y restauración. Evidencia: políticas, inventarios, pruebas de restauración, configuraciones, accesos y tiempos observados.

21. Disponibilidad, resiliencia regional y dominios de falla

Diseñar según requisitos de resiliencia entre zonas, regiones, servicios, identidad, redes, DNS, datos y proveedores. Evidencia: arquitectura, dependencias, pruebas de failover, capacidad, límites y acciones correctivas.

22. Respuesta a incidentes, forense y preservación de evidencia cloud

Preparar playbooks para compromiso de identidad, exposición de datos, cargas maliciosas, ransomware y abuso del plano de control. Evidencia: playbooks, cronologías, snapshots, logs, casos con proveedor, ejercicios y lecciones.

23. Inventario, descubrimiento, propiedad y etiquetado de activos

Identificar continuamente recursos, activos efímeros, endpoints públicos, datos, claves, cargas e integraciones. Evidencia: feeds de inventario, cumplimiento de tags, recursos huérfanos, atestaciones y limpieza.

24. Riesgo de terceros, marketplaces y servicios administrados

Gobernar imágenes de marketplace, SaaS, MSP, APIs y componentes externos. Evidencia: registro, evaluaciones, permisos, contratos, monitoreo y terminación.

25. Aseguramiento de proveedores cloud y evidencia contractual

Recopilar aseguramiento proporcional al riesgo y validar alcance y período de informes, certificaciones y compromisos. Evidencia: reportes, mapeos de alcance, contratos, hallazgos, cartas puente y decisiones.

26. Privacidad, registros, retención y eliminación

Configurar servicios para apoyar obligaciones aplicables de privacidad y registros sin confundir capacidad técnica con determinación legal. Evidencia: retención, eliminación, legal holds, evaluaciones y pruebas de ciclo de vida.

27. Costos, capacidad, abuso y gobierno de recursos

Tratar costos inesperados, agotamiento, abuso de cuotas, criptominería y aprovisionamiento descontrolado como señales cuando corresponda. Evidencia: umbrales, alertas, capacidad, investigaciones y acciones.

28. Consistencia de controles multi-cloud e híbridos

Definir controles empresariales y específicos por proveedor sin ocultar diferencias materiales. Evidencia: matriz cross-cloud, patrones, desviaciones, cobertura, brechas y planes de migración.

29. Métricas, salud de controles, monitoreo continuo y excepciones

Medir exposición privilegiada, recursos públicos, violaciones, brechas de logging, riesgo sin parchear, identidades obsoletas, fallas de backup y antigüedad de excepciones. Evidencia: dashboards, definiciones, umbrales, tendencias y remediación.

30. Evaluación, aseguramiento, pruebas y muestreo de evidencia

Definir alcance, muestreo, validación técnica, revisión de configuración, pruebas e interfaces de evaluadores. La automatización no crea certificación ni sustituye juicio profesional externo. Evidencia: planes, muestras, papeles de trabajo, hallazgos y retests.

31. Migración, modernización, salida, portabilidad y desmantelamiento

Planificar migraciones y salidas seguras considerando datos, identidades, claves, configuraciones, dependencias, evidencia y eliminación. Evidencia: planes, pruebas de portabilidad, conciliación, confirmación de borrado y accesos revocados.

32. Paquete de evidencia, roadmap, cambio de fuentes y mejora continua

Registrar propietario, alcance, procedimiento, frecuencia, evidencia, prueba, hallazgos, remediación y reevaluación. Revalidar versión CCM/CAIQ, transiciones, mapeos, orientación relevante y dependencias STAR al liberar. Exigir paridad trilingüe, seis binarios reproducibles, QA de render/accesibilidad, SHA-256, seguridad de workflows, staging exacto, predecesor publicado y conciliación de registros.

Límite de liberación controlada

Esta localización no establece cumplimiento, equivalencia legal, certificación de proveedor ni estado CSA STAR. CCM v4.1 es el estado de referencia CSA registrado por el gate de fuentes y debe revalidarse al liberar. Bajo la regla canónica, un candidato limpio con gates objetivos verdes y predecesor publicado procede bajo autorización permanente salvo una cuestión sustantiva específica que requiera juicio especializado no determinístico.